

# Security+ 1.1 · Security Controls

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 1.1** — Security Controls (11:48) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

---

**Executive Lesson Summary:** Control = any measure that prevents, warns, repairs, or compensates. 4 CATEGORIES (by means): Technical (tool), Managerial (document/policy), Operational (people in daily operations), Physical (physical barrier). 6 TYPES (by purpose): Preventive (blocks before), Deterrent (discourages), Detective (warns after), Corrective (repairs), Compensating (plan B), Directive (directs). The exam provides a SCENARIO and asks for classification in both dimensions.

## High-Yield Core Concepts Tested on Exam

---

- 4×6 matrix = the mental table for this lesson
- Preventive blocks BEFORE — Detective WARNS — Corrective REPAIRS
- Compensating: uses DIFFERENT MEANS when the ideal is not feasible — temporary
- Directive = weakest: 'authorized personnel only' does not block anyone
- Antivirus: technical + preventive and detective depending on mode
- Fire extinguisher = corrective — repairs during, does NOT prevent

## Exam Tips & Classic Scenarios

---

- Triggers: 'after the event' → corrective · 'discourage' → deterrent · 'identifies/logs' → detective · 'alternative approach' → compensating
- Messer's question: 'what CATEGORY does it fit in (technical/managerial/operational/physical) AND what TYPE?'

**Typical Exam Scenario:** A typical scenario: 'organization requires two administrators to authorize payment' → compensating/managerial (separation of duties). 'Restore backup after ransomware' → corrective/technical. 'Sign without lock: authorized personnel only' → directive/physical.

## Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 1.1 — Security Controls)

---

**Why is this advanced coverage required for SY0-701?** Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

### **Classic CompTIA Traps & Question Framing:**

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

## **Practice Questions with In-Depth Solutions (10 Questions)**

---

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

**1. An administrator installs a firewall rule that blocks all inbound traffic from a known malicious IP range. Which combination correctly classifies this control?**

- A)** Preventive · Technical
- B)** Detective · Technical
- C)** Preventive · Managerial
- D)** Deterrent · Technical

**2. The company installs signs at the entrance saying 'this area is being recorded by security cameras'. No new physical device was added. What is the primary purpose of this control?**

- A) Preventive**
- B) Detective**
- C) Deterrent**
- D) Compensating**

**3. After a ransomware attack, the IT team wipes the machine's disk and restores data from yesterday's backup. This control is:**

- A) Detective**
- B) Corrective**
- C) Preventive**
- D) Compensating**

**4. A critical company software has a severe vulnerability, but the vendor can only send the patch in 2 months. The temporary solution of blocking the specific port on the firewall until the patch arrives is what type of control?**

- A) Corrective**
- B) Detective**
- C) Compensating**
- D) Preventive**

**5. The organization implements a policy that NO ONE (not even the system administrator) can approve and execute a payment alone — it always requires two people. This is:**

- A) Preventive control of the managerial type (separation of duties)**
- B) Detective control of the technical type**
- C) Compensating control of the operational type (dual guard)**
- D) Directive control of the physical type**

**6. Guards patrol the building every hour. When a guard discovers open doors that should not be open, they report it immediately. This control is:**

- A) Detective · Operational (patrol)**
- B) Preventive · Physical (patrol)**
- C) Corrective · Operational**
- D) Detective · Technical**

**7. The company writes an official security policy document that defines how employees should handle sensitive data. What is the type + category?**

- A) Directive + Managerial**
- B) Preventive + Managerial**
- C) Directive + Technical**
- D) Corrective + Managerial**

**8. After a successful attack, the security team compiles a report of what happened to prevent recurrence — including updating the playbook. Which control is this?**

- A) Detective**
- B) Corrective — in the managerial category (process, documentation)**
- C) Preventive**
- D) Compensating**

**9. The datacenter installed a motion detector that triggers an alarm and notifies guards when there is movement outside business hours. This combination is:**

- A) Detective + Technical**
- B) Detective + Physical**
- C) Preventive + Physical**
- D) Deterrent + Technical**

**10. After an incident, the security team adds an additional antivirus module at the network edge because the legacy system cannot be patched. This is an example of:**

- A) Compensating control — an alternative because the ideal control is not possible**
- B) Corrective control — fixes what has already happened**
- C) Preventive — blocks the attack before it occurs**
- D) Deterrent — discourages the attacker**

## COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

### 1) A — Preventive · Technical.

A firewall is a technological tool (Technical); the rule blocks the packet before it enters the network (Preventive).

#### ✗ Why the others are wrong:

- *Detective · Technical*: Detective controls identify and log events after they occur; a firewall rule that blocks traffic is preventive, not detective.
- *Preventive · Managerial*: Managerial controls are administrative (policies, procedures); a firewall rule is a technical control.
- *Deterrent · Technical*: Deterrent controls discourage attackers (e.g., warning banners); a firewall rule actively blocks traffic, making it preventive.

### 2) C — Deterrent.

The sign discourages and deters malicious action (Deterrent), but does not physically prevent entry nor record anything by itself. A preventive control would physically block access (e.g., locks, barriers). A detective control would detect and record events (e.g., actual cameras, motion sensors). A compensating control would be an alternative measure to satisfy a requirement when the primary control is not feasible. The sign alone serves as a deterrent by creating a perception of surveillance, which may reduce the likelihood of an attack.

### 3) B — Corrective.

Restoring from backup occurs AFTER the incident to restore the system's operational state (Corrective).

#### ✗ Why the others are wrong:

- *Detective*: Detective controls identify and log events but do not restore systems after an incident.
- *Preventive*: Preventive controls aim to stop incidents before they occur, not to recover after.
- *Compensating*: Compensating controls are alternative measures when primary controls cannot be implemented, not the restoration action itself.

### 4) C — Compensating.

Compensating control: it is a temporary alternative countermeasure applied when the primary/ideal control (the vendor patch) is not feasible at the moment.

### 5) A — Preventive control of the managerial type (separation of duties).

Separation of duties is an administrative/managerial (Managerial) policy that prevents fraud and errors by preventing unilateral action (Preventive).

### 6) A — Detective · Operational (patrol).

The correct answer is Detective · Operational (patrol). Security patrols are part of human operational procedures (Operational control type) and function by identifying anomalies during inspection (Detective control function). They do not prevent the door from being opened, nor do they correct the issue; they detect and report it. Distractor breakdown: • Preventive · Physical (patrol): Incorrect. While a patrol is a physical presence, its primary function in this scenario is detection, not prevention. A preventive physical control would be a lock or a barrier that stops unauthorized access. • Corrective · Operational: Incorrect. Corrective controls restore systems after an incident (e.g., backups, patching). The patrol does not correct the open door; it only reports it. • Detective · Technical: Incorrect. Technical controls are implemented via technology (e.g., SIEM, IDS, CCTV analytics). A human guard patrol is an operational, not technical, control.

### 7) B — Preventive + Managerial.

A security policy guides and prevents errors (Preventive) through an administrative process and organizational directive (Managerial).

#### ✗ Why the others are wrong:

- *Directive + Managerial*: While a policy is managerial, its primary function is to prevent incidents by setting rules, not merely to direct behavior. Directive controls are a subset of preventive controls, but the best classification here is Preventive + Managerial because the policy actively prevents mishandling of sensitive data.
- *Directive + Technical*: A policy is not a technical control; it is an administrative (managerial) control. Technical controls involve hardware or software mechanisms, not written documents.
- *Corrective + Managerial*: Corrective controls are used after an incident to restore systems or mitigate damage. A security policy is proactive and preventive, not corrective.

### 8) B — Corrective — in the managerial category (process, documentation).

Lessons learned and policy updates after an incident constitute a corrective control at the managerial/process level. This is a post-incident activity that aims to improve future response and prevent similar incidents.

#### ✗ Why the others are wrong:

- *Detective*: Detective controls are designed to identify and alert on security events as they occur (e.g., IDS, logs). They do not involve post-incident documentation or process improvement.
- *Preventive*: Preventive controls aim to stop incidents before they happen (e.g., firewalls, access controls). Updating a playbook after an incident is reactive, not preventive.
- *Compensating*: Compensating controls are alternative measures used when primary controls cannot be implemented. They are not specifically about post-incident learning and documentation.

### 9) B — Detective + Physical.

Motion detectors and volumetric sensors are physical devices (Physical) whose function is to detect intrusions and issue alerts (Detective). They do not prevent access but rather identify and report it, making them detective physical controls.

### 10) A — Compensating control — an alternative because the ideal control is not possible.

✓ **Why it is correct:** A compensating control is an alternative safeguard implemented when the ideal or primary control cannot be applied. In this scenario, the legacy system cannot be patched, so the team adds an antivirus module at the network edge to compensate for the missing patch, reducing risk through an alternative method.

#### ✗ Why the others are wrong:

- *Corrective control*: Corrective controls are designed to fix or restore systems after an incident has occurred (e.g., backups, patches). Here, the antivirus is added proactively to prevent future incidents, not to correct past ones.
- *Preventive*: While the antivirus does have preventive aspects, the key distinction is that it is not the primary or ideal control; it is a substitute for the missing patch. The term 'compensating' specifically addresses the inability to apply the ideal control.
- *Deterrent*: Deterrent controls discourage attackers by making them think twice (e.g., warning banners, security cameras). The antivirus module does not deter; it actively blocks malware.

